

4



Módulo 04 Controles de Acesso

Aula 03 Tecnologias de Autenticação

Introdução —

Nesta Aula serão discutidos conceitos e tecnologias que formam a base da autenticação moderna, como:

- Smart-card e dispositivos de gerenciamento de chaves;
- Protocolos IEEE 802.1X e RADIUS;
- Chaves de token e códigos estáticos;
- Autenticação aberta: HOTP, TOTP;
- Verificação em duas etapas.

Aula 03

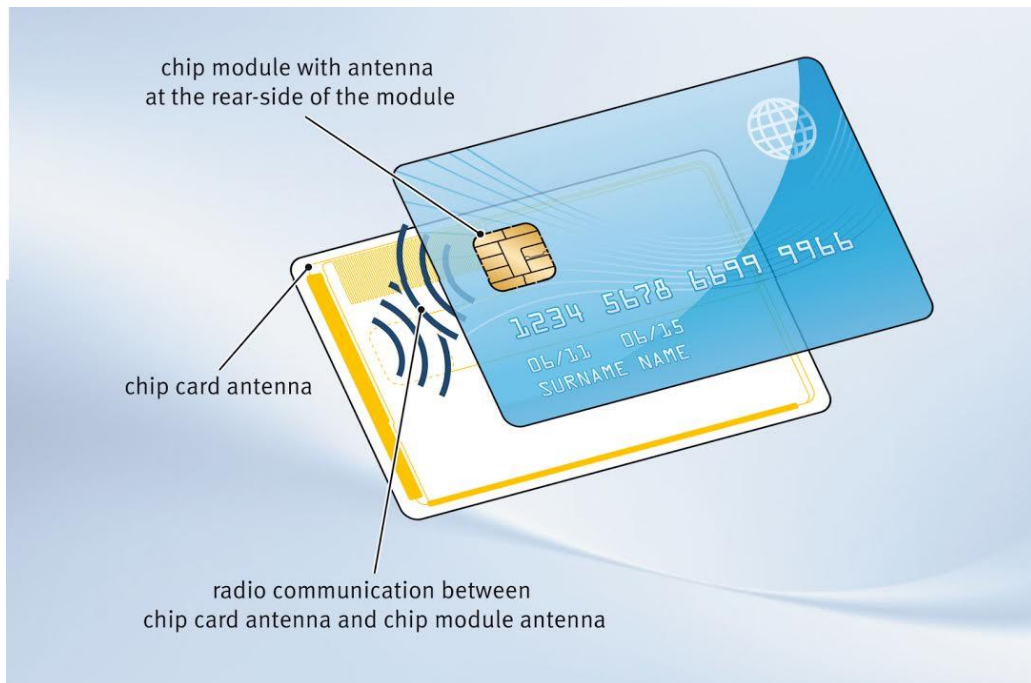
Tecnologias de Autenticação

Tecnologias Voltadas para Autenticação —

TECNOLOGIAS VOLTADAS PARA AUTENTICAÇÃO

- As tecnologias de autenticação podem estar baseadas em algo que você possui.
- Esta técnica é conhecida como *Ownership Factor*.
- A tendência, no entanto, são os sistemas de autenticação multifatorial.
- Neste caso, o sistema de autenticação utiliza mais de um fator, como por exemplo, algo que o usuário sabe e algo que o usuário possui.





Fonte: eeNews

Disponível em: <<https://www.eenewseurope.com/en/trends-in-the-smart-card-payment-industry-chip-innovations-drive-new-applications-and-services/>>

Acesso em: 25 mar. 2024.

AUTENTICAÇÃO COM SMART-CARD

- São dispositivos portáteis de armazenamento e processamento de dados.
- São usados em várias aplicações (Bancos, controle de acesso de entrada).
- Funcionamento na autenticação:
 1. Utiliza o duplo fator de autenticação (*ownership + knowledge factor*).
 2. Usuário insere o Smart-Card no leitor e fornece a senha pessoal.
 3. O microprocessador do Smart-Card realiza a validação interna da senha.
 4. Gera o código de autenticação único para acesso ao sistema.

AUTENTICAÇÃO COM SMART-CARD

- Vantagens:

1. Segurança aprimorada por dois fatores;
2. Portabilidade e conveniência;
3. Diversidade de aplicações.

- Desvantagens:

1. Custo inicial significativo;
2. Perda ou roubo;
3. Complexidade para usuários inexperientes.



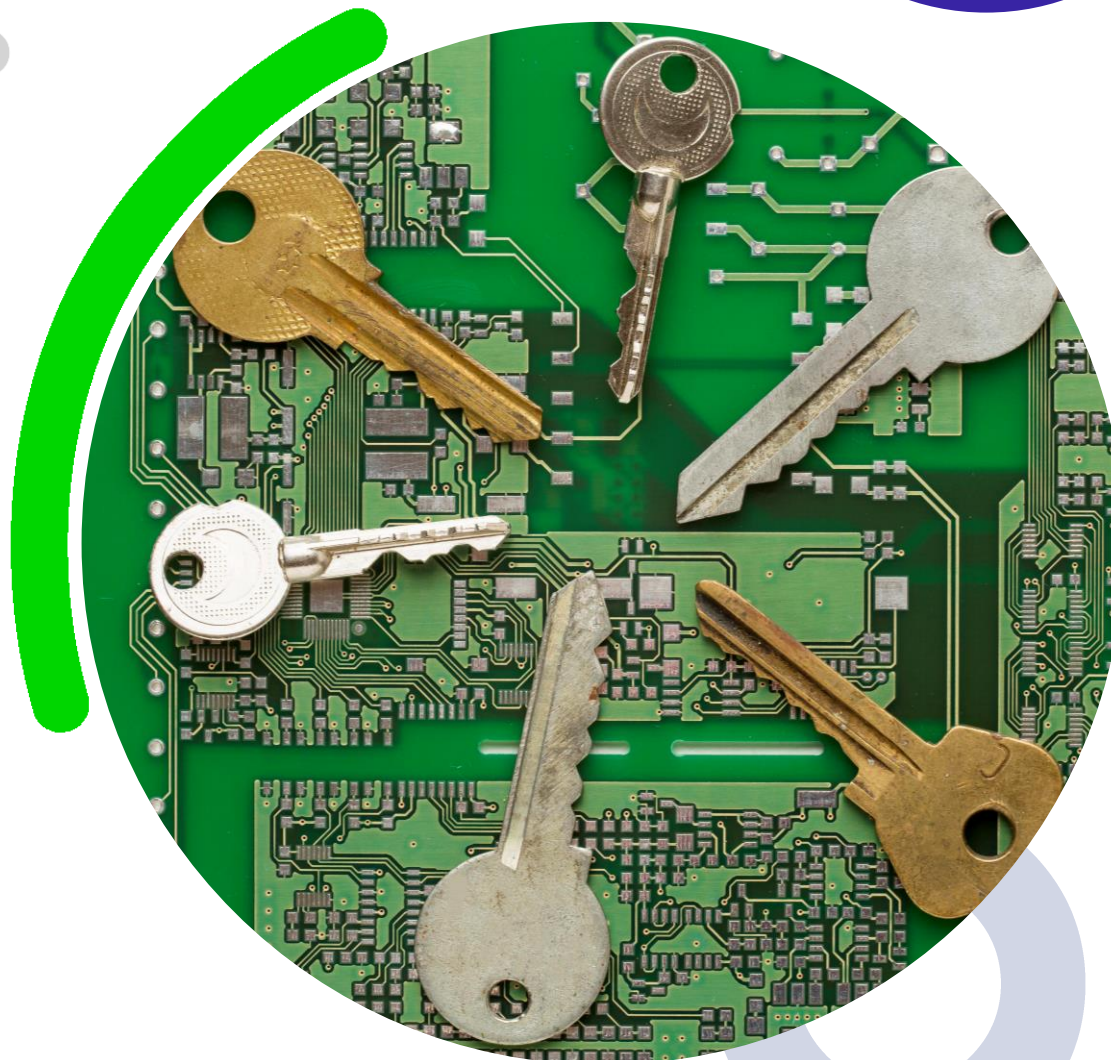


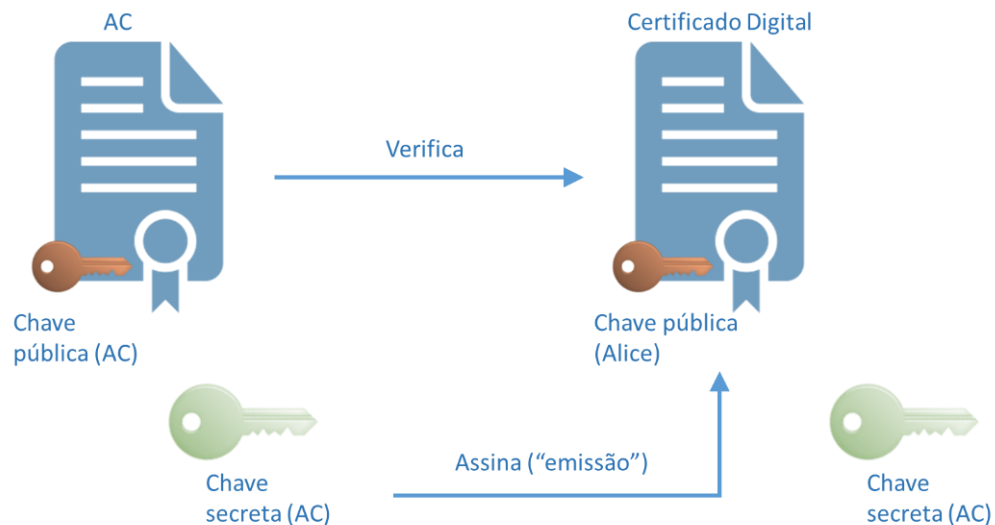
AUTENTICAÇÃO COM SMART-CARD

- Exemplos práticos de aplicação:
 1. Acesso a redes corporativas;
 2. Sistemas de saúde;
 3. Pagamentos eletrônicos;
 4. Controle de acesso físico.

DISPOSITIVOS DE GERENCIAMENTO DE CHAVES

- São responsáveis por gerar, armazenar e distribuir chaves criptográficas.
- As chaves criptográficas são utilizadas para cifrar e decifrar dados.
- Tipos de dispositivos:
 1. Hardware Security Modules (HSMs);
 2. Token USB;
 3. Trusted Platform Module (TPM);
 4. Secure Enclaves.





Fonte: WeLiveSecurity
Disponível em:
<<https://www.welivesecurity.com/br/2017/04/28/certificados-digitais-e-infraestrutura-de-chaves-publicas/>>
Acesso em: 25 mar. 2024.

DISPOSITIVOS DE GERENCIAMENTO DE CHAVES

■ Implementações práticas:

1. Criação de certificados digitais;
2. Assinatura Digital;
3. Controle de acesso a dados sensíveis.

DISPOSITIVOS DE GERENCIAMENTO DE CHAVES

— Considerações de segurança:

1. Proteção física dos dispositivos evita acesso não autorizado;
2. Atualizações e monitoramento para corrigir vulnerabilidades;
3. *Backup* e recuperação de chaves.



PROTOCOLO DE AUTENTICAÇÃO EXTENSÍVEL (IEEE 802.1X)

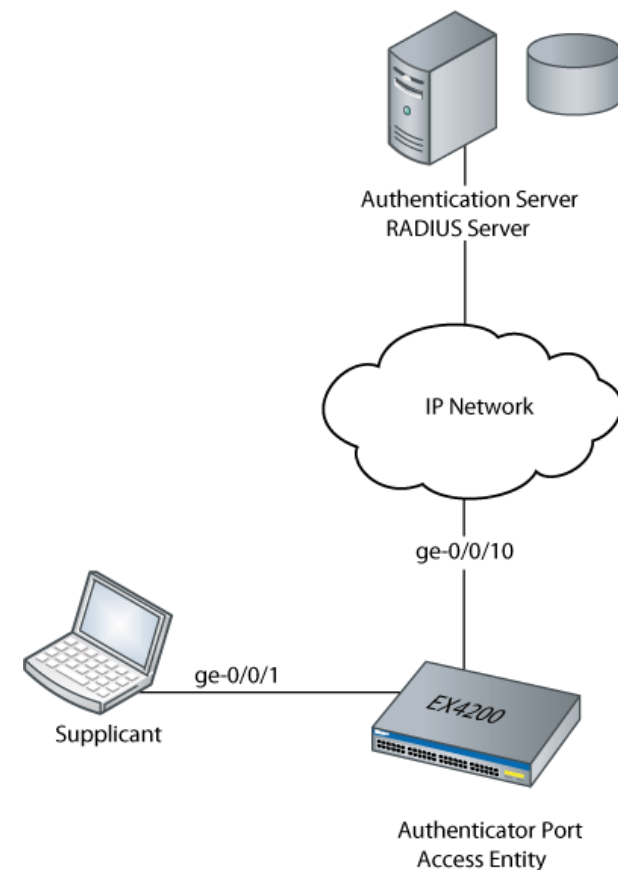
- É um protocolo de controle de acesso à rede.
- Suporta a autenticação de dispositivos à rede: computadores, impressoras e IoT (Internet of Things).
- Quanto a sua utilização:
 1. Amplamente utilizado em ambientes corporativos e institucionais;
 2. É eficaz em redes com fio e sem fio;
 3. Permite às organizações estabelecer políticas de controle de acesso;
 4. É flexível permitindo a integração com diferentes métodos de autenticação.



PROTOCOLO DE AUTENTICAÇÃO EXTENSÍVEL (IEEE 802.1X)

Componentes envolvidos:

1. Suplicante (*Supplicant*): Este é o dispositivo que busca acesso à rede;
2. Autenticador (*Authenticator*): Ponto de acesso à rede (switch, AP-Wi-Fi);
3. Servidor de Autenticação (*Authentication Server*).

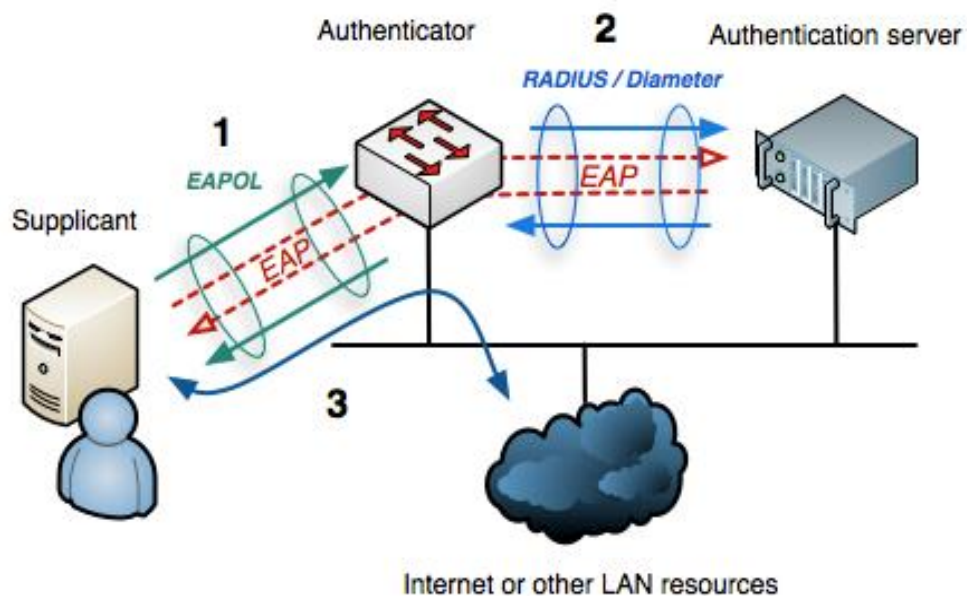


Fonte: Juniper Networks

Disponível em:

<<https://www.juniper.net/documentation/br/pt/software/junos/user-access/topics/topic-map/802-1x-authentication-switching-devices.html>>.

Acesso em: 25 mar. 2024.



Fonte: Wikipedia
Disponível em: <https://en.wikipedia.org/wiki/IEEE_802.1X>
Acesso em: 25 mar. 2024.

PROTOCOLO DE AUTENTICAÇÃO EXTENSÍVEL (IEEE 802.1X)

Funcionamento:

1. No Autenticador:

- Habilitar o IEEE 802.1X no *switch*.
- Definir portas de autenticação como portas IEEE 802.1X.
- Especificar o servidor de autenticação (geralmente um servidor RADIUS).

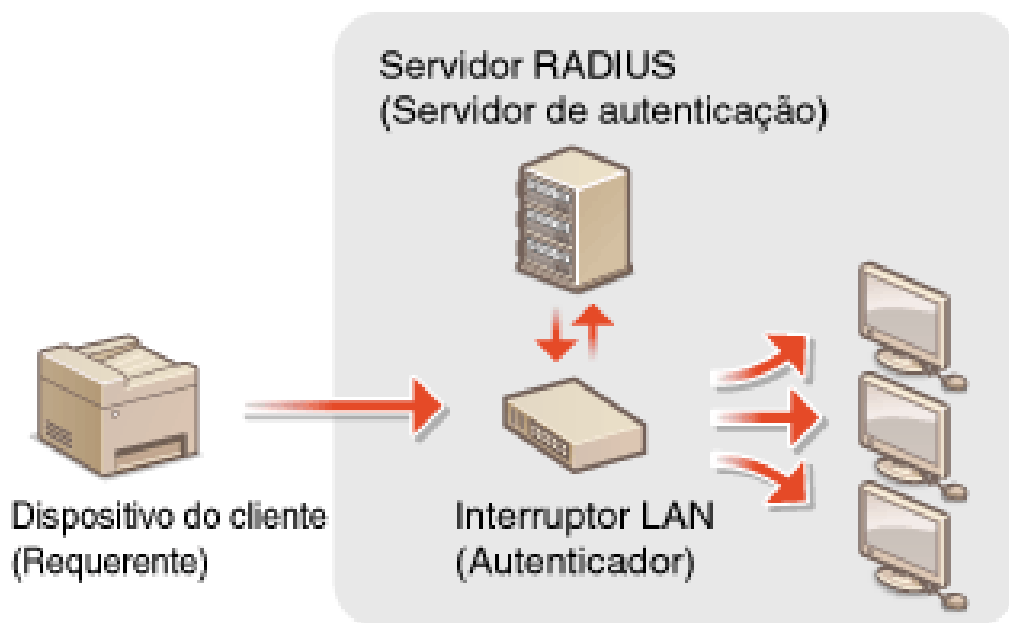
PROTOCOLO DE AUTENTICAÇÃO EXTENSÍVEL (IEEE 802.1X)

2. No Suplicante:

- Configurar o dispositivo cliente para iniciar o processo e definir os parâmetros de autenticação IEEE 802.1X.

3. No Servidor de Autenticação (RADIUS):

- Configurar o RADIUS para se comunicar com o *switch* e definir políticas de autenticação e autorização para os Suplicantes.



Fonte: Portal do Manual do Usuário Canon

Disponível em: <https://oip.manual.canon/USRMA-0820-zz-SS-ptBR/contents/SS419_security_236configuringieee8021xauthentication.html>

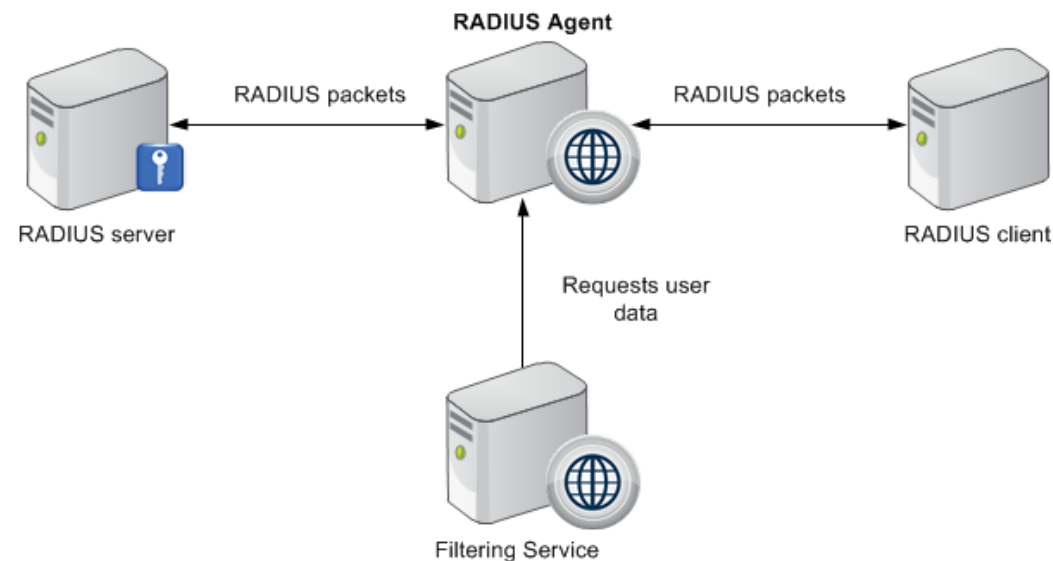
Acesso em: 25 mar. 2024.

SERVIÇO DE USUÁRIO DE DISCAGEM DE AUTENTICAÇÃO REMOTA (RADIUS)

- É um protocolo de rede utilizado para gerenciar a autenticação, autorização e contabilidade (AAA).

1. Funcionamento:

- O RADIUS opera em um modelo cliente-servidor.
- O cliente (switch ou AP) envia solicitação;
- O servidor RADIUS processa a solicitação;
- Autentica os usuários e fornece as informações de autorização necessárias.



Fonte: Forcepoint

Disponível em:

<https://www.websense.com/content/support/library/web/v84/radius_agent/ra_radius_id.aspx>

Acesso em: 25 mar. 2024.

SERVIÇO DE USUÁRIO DE DISCAGEM DE AUTENTICAÇÃO REMOTA (RADIUS)

2. Papel do RADIUS na autenticação:

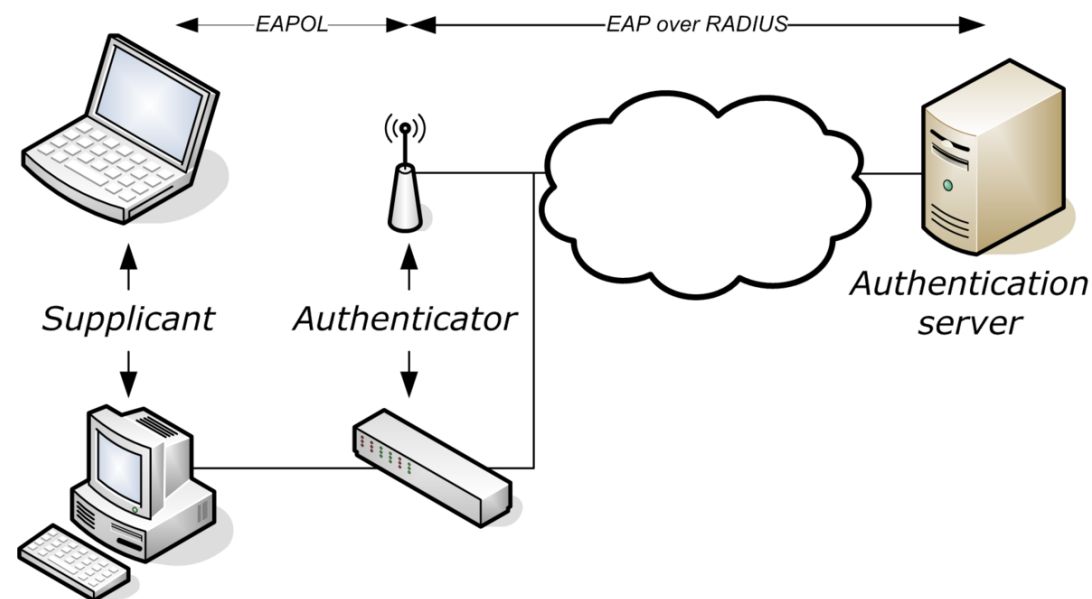
- A função principal é facilitar a comunicação segura entre o cliente e o servidor RADIUS.

3. Papel do RADIUS na autorização:

- Determina os recursos e serviços autorizados para o usuário autenticado.

4. Accounting:

- Suporta a contabilidade.



Fonte: Wikipedia

Disponível em:

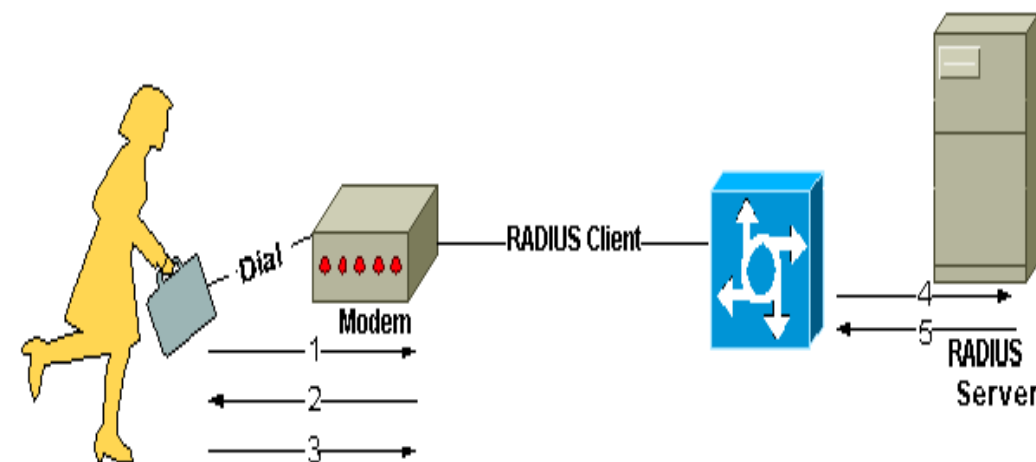
<https://pt.wikipedia.org/wiki/Extensible_Authentication_Protocol>

Acesso em: 25 mar. 2024.

SERVIÇO DE USUÁRIO DE DISCAGEM DE AUTENTICAÇÃO REMOTA (RADIUS)

5. Exemplos de Cenários de Aplicação:

- Redes corporativas;
- Provedores de Serviços de Internet (ISPs);
- Telecomunicações;
- Redes de campus universitários.



Fonte: Cisco

Disponível em: <https://www.cisco.com/c/pt_br/support/docs/security-vpn/remote-authentication-dial-user-service-radius/12433-32.html>

Acesso em: 25 mar. 2024.

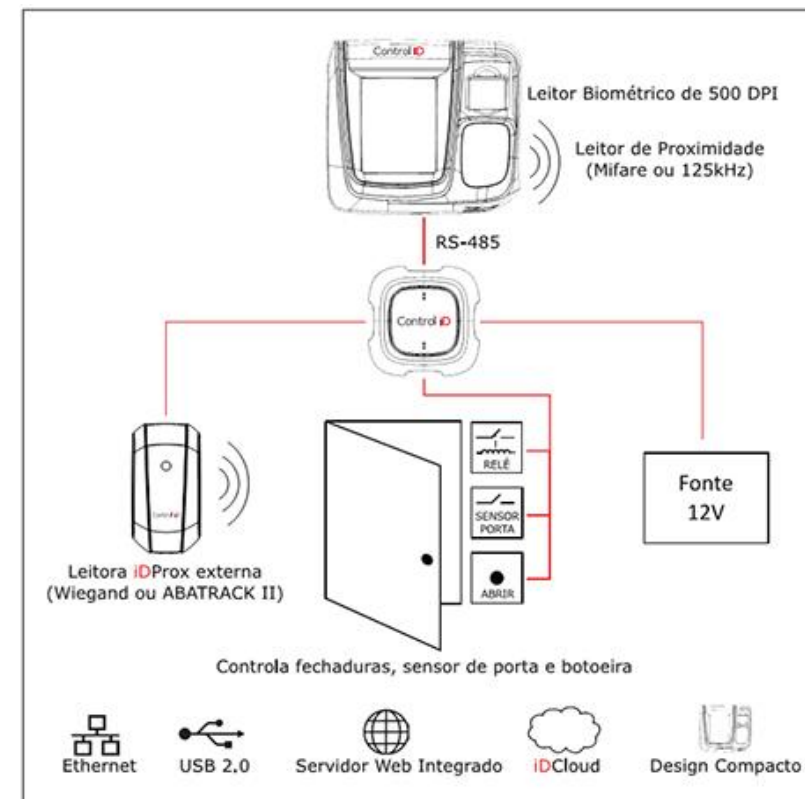


SISTEMA DE CONTROLE DE ACESSO DO CONTROLADOR DE ACESSO TERMINAL

- Refere-se à prática de gerenciar e regular o acesso a terminais ou dispositivos finais em uma rede.
- Funcionamento:
 - Autenticação dos usuários envolvendo verificação de credenciais.
 - Autorização de acesso determinando as permissões do usuário.
 - Auditoria e registro de todas as atividades realizadas.
 - Controle de sessão.
 - Integração com outros sistemas.

SISTEMA DE CONTROLE DE ACESSO DO CONTROLADOR DE ACESSO TERMINAL

- Casos práticos de utilização:
 - Administração de redes.
 - Gerenciamento de servidores.
 - Operações de telecomunicações.
 - Segurança industrial.
 - Ambiente de computação em Nuvem.



Fonte: Amazon

Disponível em: <<https://www.amazon.com.br/Controle-Acesso-IDFlex-Prox-Colorida/dp/B09KQW8DY8>>

Acesso em: 25 mar. 2024.



CHAVES DE TOKEN

- São códigos gerados por um dispositivo de HW ou SW conhecidos como "token".
- Uso para autenticação:
 - o Geração dinâmica – códigos únicos de curta duração fornecidos junto com as credencias de login.
 - o Aplicação móvel - geradas por aplicativos móveis onde o dispositivo é o token.

CHAVES DE TOKEN

- Considerações de segurança:
 - Temporalidade – reduz o risco de comprometimento.
 - Proteção do token – dispositivos comprometidos, expõem a autenticação.
 - Implementação adequada – garante a eficácia das chaves de token.
- Exemplos práticos: Google Authenticator, RSA SecurID.



Fonte: G1¹

¹ Disponível em:
<https://g1.globo.com/tecnologia/noticia/2012/06/pesquisadores-extraem-chaves-secretas-de-aparelhos-de-seguranca.html>
Acesso em: 25 mar. 2024.

Two-Factor Authentication





USERNAME



Remember me

Forgot password

LOGIN

CÓDIGOS ESTÁTICOS

- São senhas ou códigos que permanecem constantes, não mudam com o tempo.
- Uso na autenticação:
 - o Combinados com códigos temporários (2FA).
 - o Acesso a áreas restritas.
- Considerações de segurança:
 - o Riscos de reutilização.
 - o Necessidade de combinar com outros métodos.

CÓDIGOS ESTÁTICOS

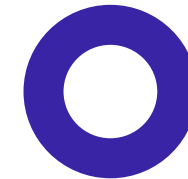
Exemplos práticos:

- Cartões de Acesso com Código PIN - usados para acessar edifícios ou áreas restritas.
- Códigos de Recuperação de Conta.

AUTENTICAÇÃO ABERTA: HOTP E TOTP

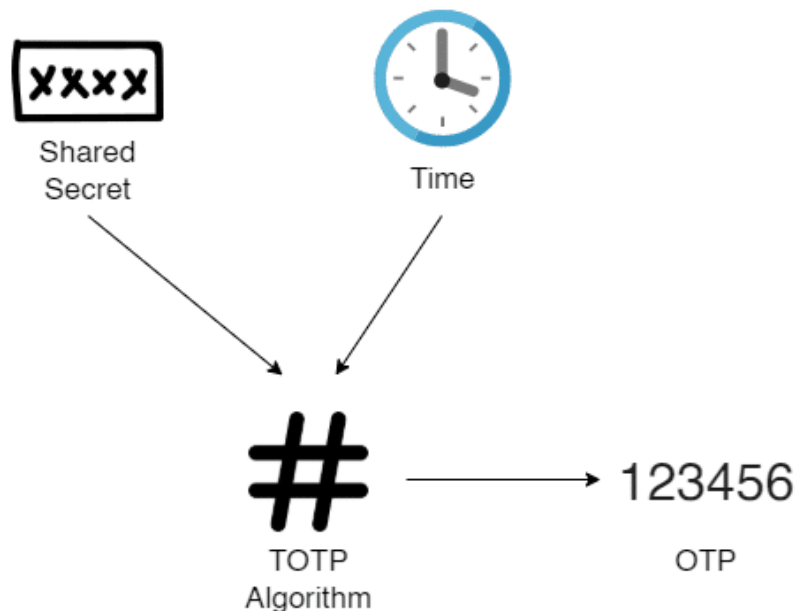
- HOTP (HMAC-based One-Time Password) é um algoritmo de autenticação baseado em HMAC (Hash-based Message Authentication Code).
- Funcionamento:
 - Gera senhas únicas válidas apenas durante uma transação ou sessão.
 - Uma chave secreta é compartilhada pelo servidor e o dispositivo do usuário.
 - O código de autenticação é gerado por meio de uma função *hash* da chave secreta combinada com um contador.





AUTENTICAÇÃO ABERTA: HOTP E TOTP

- TOTP (Time-based One-Time Password) é uma variação do HOTP.
- Em vez de depender de um contador, ele utiliza um fator de tempo.
- Funcionamento:
 - A senha única é gerada com base no tempo atual e na chave secreta compartilhada.
 - Exige sincronia temporal entre o dispositivo do usuário e o servidor.



Fonte: Rublon

Disponível em: <<https://rublon.com/blog/what-is-totp/>>

Acesso em: 25 mar. 2024.

AUTENTICAÇÃO ABERTA: HOTP E TOTP

Diferenças entre eles:

- Método de geração: Contador vs. Tempo Atual.
- Sincronia temporal: TOTP exige sincronia temporal.
- Validade dos códigos: HOTP os códigos são válidos até serem usados vs. TOTP os códigos são válidos por um curto período de tempo.
- Implementação: HOTP é adequado se a sincronia temporal é difícil vs. TOTP quando a sincronia temporal pode ser suportada.

HOTP vs. TOTP: What's the difference?



Hash-based OTPs

- ✓ The moving factor is a counter
- ✓ Passwords are generated with an algorithm that uses a counter
- ✓ Passwords expire after use or a new OTP is requested
- ✓ Also known as event-based OTPs

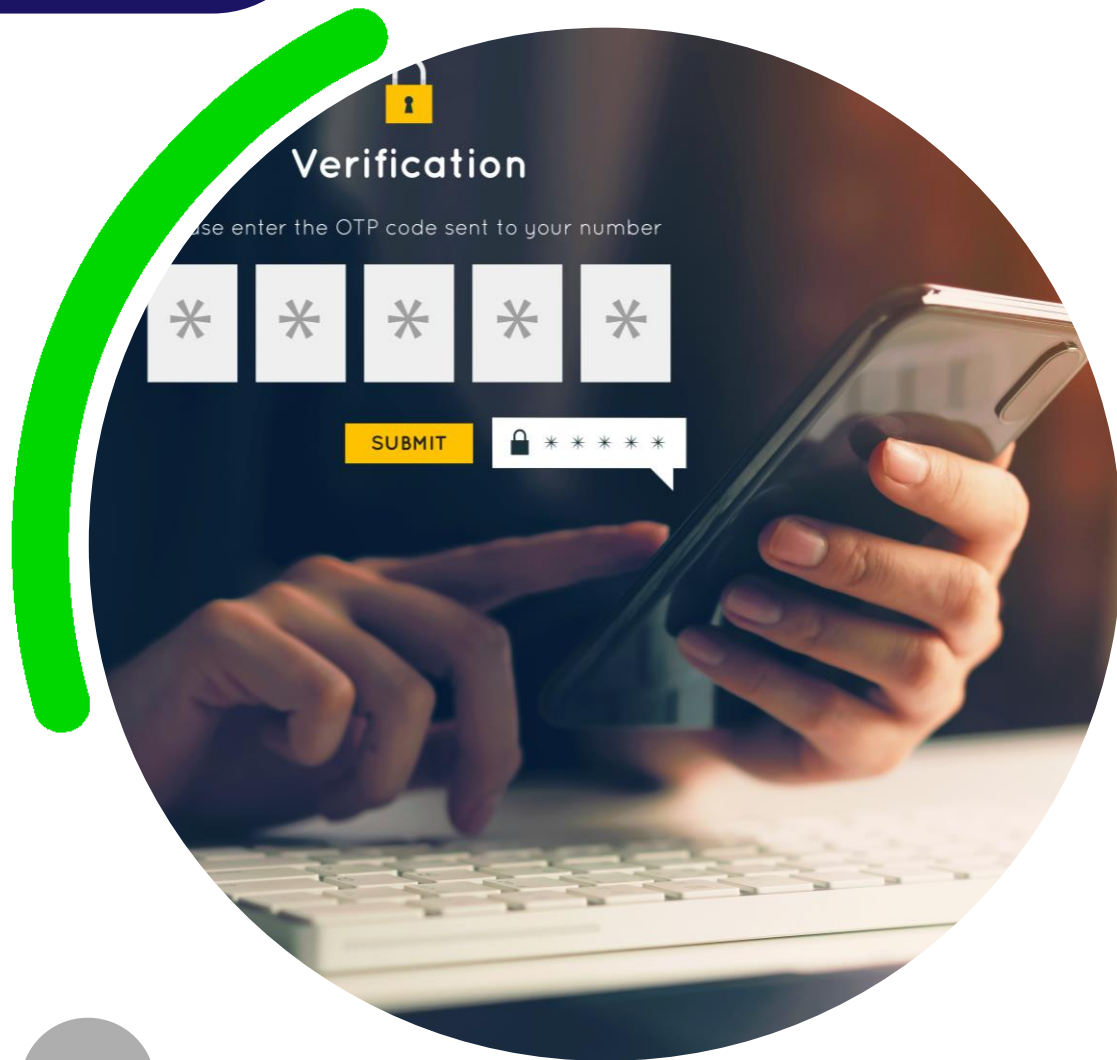
Time-based OTPs

- ✓ Moving factor = time
- ✓ The password includes the exact time of its request
- ✓ Passwords expire after use or a certain amount of time has passed
- ✓ Also known as app-based authentication or software tokens

Fonte: Sinch

Disponível em: <<https://www.sinch.com/blog/one-time-password/>>

Acesso em: 25 mar. 2024.



AUTENTICAÇÃO ABERTA: HOTP E TOTP

Aplicações práticas:

- Autenticação em Dois Fatores (2FA).
- Acesso a Aplicações Corporativas.
- Proteção de Contas Online.
- Controle de Acesso Físico.
- Ambientes de IoT (Internet of Things).

VERIFICAÇÃO EM DUAS ETAPAS

- Requer duas formas distintas de autenticação (senha + token físico, por exemplo).
- Valor para a segurança:
 - Mitigação de Riscos de Senhas Comprometidas..
 - Fortalecimento da Segurança Online.
 - Proteção contra Ataques de Engenharia Social.
 - Conformidade com Padrões de Segurança.





Fonte: NetIQ

Disponível em: <https://www.netiq.com/documentation/cloudaccess-2-2/install_config/data/config-otp.html>

Acesso em: 25 mar. 2024.

VERIFICAÇÃO EM DUAS ETAPAS

Exemplos de implementação:

- Códigos de Verificação via Mensagem de Texto (SMS).
- Aplicativos de Autenticação.
- Tokens de Hardware.
- Biometria como Segunda Etapa.

VERIFICAÇÃO EM DUAS ETAPAS

Boas práticas:

- Diversificação de Fatores.
- Educação do Usuário.
- Atualizações e Revisões Periódicas.
- Backup de Códigos de Recuperação.
- Integração com Ferramentas de Gerenciamento de Identidade.



4



Você chegou ao final da Aula 03
**Tecnologias de
Autenticação**